

Compliance Gap Analysis Report

SAMA Cyber Security Framework
Prepared for: Al-Falak Digital Bank
Generated: 2026-07-29 14:45

Executive Summary

Status	Count	Percentage
Compliant	32	88.9%
Partially Compliant	4	11.1%
Non-Compliant	0	0.0%

Detailed Findings

Control	Domain	Status	Justification	Recommendation
3.1.1 Cyber Security Governance	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly addresses all requirements of the control, including establishing a cyber security committee, defining its objectives and roles, establishing a cyber security function, and ensuring the CISO meets specific qualifications and has a Saudi nationality.	-
3.1.2 Cyber Security Strategy	Cybersecurity Governance and Leadership	Compliant	The company has defined, approved, and maintained a cyber security strategy through the Cyber Security Committee, which is aligned with the Member Organization's overall objectives, legal and regulatory compliance requirements, and the Banking Sector's cyber security strategy. The strategy addresses the importance and benefits of cyber security, the anticipated future state of cyber security, and the execution of cyber security initiatives and projects.	-
3.1.3 Cyber Security Policy	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and communicating the cyber security policy, as well as reviewing it periodically. The policy also includes a definition of cyber security, the organization's overall cyber security objectives and scope, and a statement of the board's intent.	-

Control	Domain	Status	Justification	Recommendation
3.1.4 Cyber Security Roles and Responsibilities	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly defines the roles and responsibilities of the Board of Directors, Cyber Security Committee, senior management, CISO, and internal audit function, aligning with the control's requirements.	-
3.1.5 Cyber Security in Project Management	Cybersecurity Governance and Leadership	Partially Compliant	The company's policy addresses some aspects of integrating cyber security into project management, such as defining a Cyber Security Committee and a formal project management methodology. However, it does not explicitly ensure that cyber security risks are identified and addressed as part of a project, or that a risk assessment is performed at the start of the project.	The company should explicitly require that a risk assessment be performed at the start of each project to identify and address cyber security risks, and that these risks be registered in the project-risk register and tracked.
3.1.6 Cyber Security Awareness	Cybersecurity Governance and Leadership	Partially Compliant	The company policy defines a Cyber Security Committee and a dedicated Cyber Security function, but it does not explicitly mention a cyber security awareness program for staff, third parties, and customers, nor does it address the periodic conduct of the program, the use of multiple channels, or the evaluation of its effectiveness.	Define and document a cyber security awareness program that includes regular activities for staff, third parties, and customers, and evaluate its effectiveness periodically to ensure a positive cyber security culture.
3.1.7 Cyber Security Training	Cybersecurity Governance and Leadership	Compliant	The company's policy addresses the provision of specialist or security-related skills training to staff in relevant functional area categories, including key roles, cyber security function, staff involved in developing and maintaining information assets, and staff involved in risk assessments. The policy also mentions the ongoing process of identifying, analyzing, responding, and monitoring and reviewing risks, including cyber security risk management.	-
3.2.1 Cyber Security Risk Management	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and implementing a cyber security risk management process, aligning it with the enterprise risk management process, and involving various stakeholders in the process.	-
3.2.1.1 Cyber Security Risk Identification	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses cyber security risk identification, including relevant assets, threats, existing controls, and vulnerabilities, and documents identified risks in a central register.	-

Control	Domain	Status	Justification	Recommendation
3.2.1.2 Cyber Security Risk Analysis	Cyber Security Risk Management and Compliance	Compliant	The company's policy explicitly addresses the control's requirements by mentioning the need for a cyber security risk analysis, the consideration of the level of potential business impact and likelihood of cyber security threat events materializing, and the involvement of the Cyber Security Committee in the risk analysis process.	-
3.2.1.3 Cyber Security Risk Response	Cyber Security Risk Management and Compliance	Compliant	The company's policy documents (Excerpts 2, 3, and 5) clearly address the control's requirements, including the establishment of a Cyber Security Committee, risk treatment options, and documentation of risk treatment actions in a risk treatment plan.	-
3.2.1.4 Cyber Risk Monitoring and Review	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the monitoring of cyber security risk treatment, tracking progress in accordance with treatment plans, and reviewing the design and effectiveness of revised or newly implemented cyber security controls.	-
3.2.2 Regulatory Compliance	Cyber Security Risk Management and Compliance	Compliant	The company has established a process for ensuring compliance with relevant regulatory requirements, involving the Cyber Security Committee, and resulting in the update of cyber security policy, standards, and procedures. This process is performed periodically and involves representatives from key areas of the organization.	-
3.2.3 Compliance with (inter)national industry standards	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly states compliance with PCI-DSS, EMV technical standard, and SWIFT Customer Security Controls Framework (CSCF), March 2017 version, and provides evidence of annual self-attestation and certification.	-
3.2.4 Cyber Security Review	Cyber Security Risk Management and Compliance	Compliant	The company's policy explicitly mentions annual reviews and penetration tests for customer and internet-facing services (Excerpt 5), and records the results of reviews, including issues identified and recommended actions (Excerpt 3).	-

Control	Domain	Status	Justification	Recommendation
3.2.5 Cyber Security Audits	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the control's requirements, including independent audits according to generally accepted auditing standards and SAMA's framework, as well as regular monitoring of cyber security controls' effectiveness.	-
3.3.1 Human Resources	Cyber Security Operations and Technology	Partially Compliant	The company policy defines a Cyber Security Committee and a dedicated Cyber Security function, but it does not explicitly mention incorporating cyber security requirements into human resources processes, nor does it detail the monitoring, measurement, and periodic evaluation of the effectiveness of the human resources process.	Formalize the incorporation of cyber security requirements into human resources processes, including defining, approving, and implementing cyber security responsibilities and non-disclosure clauses within staff agreements, and monitoring the effectiveness of the human resources process.
3.3.2 Physical Security	Cyber Security Operations and Technology	Compliant	The company's policy defines, approves, and implements a physical security process (Excerpt 5), monitors its effectiveness quarterly, and reviews it annually. The process includes protection of data centers and data rooms, environmental protection, and protection of information assets during their lifecycle.	-
3.3.3 Asset Management	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented an asset management process, as shown in Excerpt 5, which includes a unified register, ownership and custodianship of information assets, and information asset classification, labeling, and handling. The effectiveness of the asset management process is also monitored and evaluated annually.	-
3.3.4 Cyber Security Architecture	Cyber Security Operations and Technology	Compliant	The company's policy clearly defines, approves, and implements a cyber security architecture, including a strategic outline of cyber security capabilities and controls, approval of the defined architecture, qualified cyber security architects, design principles for developing cyber security controls, and periodic review of the architecture.	-

Control	Domain	Status	Justification	Recommendation
3.3.5 Identity and Access Management	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and implementing the identity and access management policy, monitoring compliance, measuring and evaluating the effectiveness of the policy, and including business requirements for access control, user access management, automation, centralization, multi-factor authentication, and privileged and remote access management.	-
3.3.6 Application Security	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and implementing application security standards, monitoring compliance, measuring and evaluating effectiveness, following a secure SDLC methodology, and including secure coding standards, segregation of duties, data protection, vulnerability and patch management, and back-up and recovery procedures in their application security standard.	-
3.3.7 Change Management	Cyber Security Operations and Technology	Compliant	The company's policy defines, approves, and implements a change management process (Excerpt 1, 4, and 6) that controls all changes to information assets, monitors compliance, and measures effectiveness (Excerpt 1, 4, and 6).	-
3.3.8 Infrastructure Security	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and implementing infrastructure security standards, monitoring compliance, measuring and evaluating effectiveness, and covering all instances of infrastructure.	-
3.3.9 Cryptography	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a formal Cryptographic Security Standard (Excerpt 3), which includes an overview of approved cryptographic solutions, relevant restrictions, circumstances for application, and a complete encryption key management lifecycle.	-

Control	Domain	Status	Justification	Recommendation
3.3.10 Bring Your Own Device (BYOD)	Cyber Security Operations and Technology	Partially Compliant	The company has a defined, approved, and implemented BYOD cyber security standard, but the excerpts do not show the standard's details, such as user responsibilities, restrictions, and consequences, or the regulation of corporate mobile applications.	Develop and document the BYOD standard, including user responsibilities, restrictions, and consequences, and the regulation of corporate mobile applications, and ensure it is approved and implemented.
3.3.11 Secure Disposal of Information Assets	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a secure disposal standard and procedure (Excerpt 6), monitors compliance with it (Excerpt 6), measures its effectiveness annually (Excerpt 6), and ensures disposal in accordance with legal and regulatory requirements (Excerpt 6).	-
3.3.12 Payment Systems	Cyber Security Operations and Technology	Compliant	The company has defined, approved, implemented, and monitors a cyber security standard for payment systems, as shown in Excerpt 3, which documents the Cryptographic Security Standard, its implementation, and quarterly monitoring.	-
3.3.13 Electronic Banking Services	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a cyber security standard for electronic banking services, and its effectiveness is measured and periodically evaluated. The standard covers various aspects of electronic banking services security, including multi-factor authentication, use of official application stores, and detection measures for malicious apps and websites.	-
3.3.14 Cyber Security Event Management	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a security event management process (Vulnerability Management) that includes requirements for a designated team (Cyber Security function), skilled and trained staff, resources for continuous security event monitoring activities, detection and handling of malicious code and software, and automated and centralized analysis of security loggings.	-
3.3.15 Cyber Security Incident Management	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a cyber security incident management process (Excerpt 4: Incident Response Team (CERT): Staffed 24x7 - 6 certified forensic analysts on roster) and measures its effectiveness (Excerpt 4: Weekly (internet-facing) / Monthly (internal) - last scan: 20).	-

Control	Domain	Status	Justification	Recommendation
3.3.16 Threat Management	Cyber Security Operations and Technology	Compliant	The company has defined, approved, and implemented a threat intelligence management process, which includes the use of internal and external sources, a defined methodology for analysis, and sharing of relevant intelligence with stakeholders. The effectiveness of this process is also measured and periodically evaluated.	-
3.3.17 Vulnerability Management	Cyber Security Operations and Technology	Compliant	The company's policy clearly defines, approves, and implements a vulnerability management process, measures its effectiveness, and evaluates it periodically. It also addresses all the specific requirements mentioned in the control, including frequency of vulnerability scans, classification of vulnerabilities, defined timelines to mitigate, prioritization for classified information assets, and patch management.	-
3.4.1 Contract and Vendor Management	Third Party Cyber Security	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, implementing, and monitoring cyber security controls within the contract and vendor management processes, as well as measuring and periodically evaluating their effectiveness.	-
3.4.2 Outsourcing	Third Party Cyber Security	Compliant	The company's policy clearly addresses the control's requirements, including defining, implementing, and monitoring cyber security controls within the outsourcing policy and process, measuring and evaluating their effectiveness, and involving the cyber security function in the outsourcing process.	-
3.4.3 Cloud Computing	Third Party Cyber Security	Compliant	The company's policy clearly addresses all requirements for the Cloud Computing Policy, including risk assessment, SAMA approval, contract requirements, data location, data use limitations, security, data segregation, business continuity, audit, review, and monitoring, and exit clauses.	-